TEKNOLOGI REKAYASA KOMPUTER (TRK) • SISTEM KOMUNIKASI NIRKABEL

Serangan Nirkabel Modern & Arsitektur Keamanan Enterprise

Pertemuan 2 (Minggu X) | Alokasi Waktu: 210 Menit (3 x 70 Menit) (Terapan & Praktis Network Engineer)

Dosen Pengampu: M. Riza Nurtam, M.Kom
Jurusan Rekayasa Pertanian dan Komputer - Politeknik Pertanian Negeri Pangkajene dan Kepulauan

Reload Pertemuan 1: Kriptografi Kuat vs Celah Protokol

Jembatan Konseptual: Menghubungkan Pemahaman Sebelumnya Menuju Tantangan Baru

KILAS BALIK MATERI SEBELUMNYA (YANG SUDAH DIKUASAI)

- **Fondasi Enkripsi AES-128:** Secara matematis block cipher AES-128 tidak pernah berhasil dipecahkan; payload data dienkripsi dengan sangat aman di udara.
- **Derivasi Kunci Master (PMK):** Dihasilkan melalui fungsi PBKDF2 dari kata sandi dan SSID sebagai salt kriptografi pencegah rainbow table.
- **Kunci Sesi Unicast (PTK):** Dinegosiasikan melalui 4-Way Handshake EAPoL untuk menghasilkan 4 sub-kunci (KCK, KEK, TK, MIC).
- **Celah WPA2-PSK:** Pesan M1 dan M2 dapat disadap untuk melancarkan Offline Dictionary Attack jika password pendek/lemah.

KONEKSI KE HARI INI (MENGAPA MATERI INI DIBUTUHKAN?)

→ **Paradoks Keamanan Nirkabel:** Jika enkripsi AES-128 tidak bisa dibobol, mengapa jaringan Wi-Fi kampus dan korporasi masih sangat sering kebobolan?

→ **Prinsip 'Weakest Link':** Penyerang tidak membuang waktu memecahkan AES; mereka menyerang kelemahan protokol di sekelilingnya (frame manajemen tanpa enkripsi, penipuan identitas AP, dan celah state-machine).

→ **Kebutuhan Solusi Enterprise:** Sistem kampus membutuhkan penghapusan single-password bersama beralih ke otentikasi individu IEEE 802.1X (RADIUS) dan perlindungan frame PMF (802.11w).

KATA KUNCI PEMBELAJARAN TERPADU: Kriptografi yang kuat (AES-128) akan runtuh jika arsitektur sistem di sekelilingnya rapuh. Keamanan nirkabel sejati menuntut pertahanan berlapis (Defense-in-Depth)!

Rencana Perkuliahan Modul Serangan & Enterprise (210 Menit)

Alur terstruktur dari analisis serangan aktif lapangan hingga blueprint hardening router kampus.

SESI PERTAMA: ANATOMI SERANGAN AKTIF LAPANGAN

- **Sesi 1 (00:00 - 00:35):** Review Kritis & Taksonomi Serangan: Mengapa AES saja tidak cukup, 4 pilar ancaman nirkabel (DoS, MitM, Key Theft, Rogue Infrastructure).
- **Sesi 2 (00:35 - 01:25):** Eksploitasi Frame Manajemen & Rogue AP/Evil Twin: Deauth flooding via aireplay-ng, bahaya colokan LAN liar, kloning AP, dan phishing captive portal.
- **Sesi 3 (01:25 - 01:45):** Istirahat & Diskusi Interaktif: Analisis kasus pembobolan kredensial mahasiswa di jaringan publik.

SESI KEDUA: SERANGAN LANJUTAN & BLUEPRINT ENTERPRISE

- **Sesi 4 (01:45 - 02:35):** KRACK, PMKID, & Arsitektur WPA-Enterprise: Eksploitasi Message 3 handshake, clientless PMKID attack, 3 komponen IEEE 802.1X (Supplicant, Authenticator, RADIUS), dan komparasi EAP-TLS vs PEAP.
- **Sesi 5 (02:35 - 03:10):** Sistem Pertahanan & Hardening WLAN: Protected Management Frames (PMF 802.11w), WIDS/WIPS Rogue Containment, Client Isolation, dan segmentasi multi-VLAN.
- **Sesi 6 (03:10 - 03:30):** Rangkuman Modul Keamanan & Briefing Praktikum: Checklist audit router MikroTik dan pengantar simulasi lab.

FOKUS PRAKTISI NETWORK ENGINEER: Bukan sekadar tahu cara meretas, melainkan memahami mekanisme di balik serangan agar mampu mendesain konfigurasi benteng pertahanan jaringan kampus yang kebal serangan aktif.

Taksonomi 4 Pilar Serangan Nirkabel Modern

Klasifikasi terstruktur seluruh vektor serangan nirkabel yang mengancam infrastruktur kampus.

PILAR 1 & 2: KETERSEDIAAN & PENYADAPAN AKTIF

- **1. Denial of Service (DoS):** Melumpuhkan akses koneksi pengguna secara paksa: Deauthentication Flooding (memutus klien dari AP), Beacon Flooding (membanjiri udara dengan ribuan SSID palsu), dan RF Jamming (mengacaukan frekuensi radio secara fisik).
- **2. Man-in-the-Middle (MitM):** Menyisipkan diri di antara klien dan gerbang internet: Evil Twin Access Point (AP penipu berkekuatan sinyal tinggi), Fake Captive Portal Phishing, serta ARP Poisoning / DNS Spoofing di subnet lokal.

PILAR 3 & 4: PENCURIAN KUNCI & INFRASTRUKTUR LIAR

- **3. Credential & Key Theft:** Membongkar kunci enkripsi dan akun login: Offline Dictionary Attack via Hashcat, PMKID Clientless Attack, serta manipulasi penginstalan ulang kunci (KRACK Attack).
- **4. Rogue Infrastructure:** Pemasangan perangkat fisik tidak sah di dalam gedung: Rogue AP (router rumahan dicolok staf ke switch kampus) dan Honeypot Wi-Fi pengumpul data privasi.

PARADIGMA PERTAHANAN BERLAPIS (DEFENSE-IN-DEPTH): Mengamankan jaringan nirkabel tidak cukup hanya dengan memberi password router; dibutuhkan segmentasi VLAN, otentikasi RADIUS, isolasi klien, dan firewall terintegrasi.

Bedah Istilah: Deauthentication Flooding Attack

Bagaimana frame pemutusan koneksi standar 802.11 disalahgunakan untuk melumpuhkan pengguna.

CACAT FUNDAMENTAL PADA STANDAR 802.11 LAMA

- **Apa itu Frame Deautentikasi?:** Frame manajemen resmi dalam standar 802.11 yang dikirim oleh AP untuk memberi tahu perangkat klien bahwa sesi koneksinya telah diakhiri (misal saat router reboot).
- **Masalah Protokol Konvensional:** Pada WPA/WPA2 tanpa fitur 802.11w, SELURUH FRAME MANAJEMEN DIKIRIM DALAM FORMAT PLAINTEXT DAN TANPA VERIFIKASI IDENTITAS PENGIRIM!
- **Kepatuhan Buta Kartu Klien:** Begitu smartphone atau laptop menerima frame Deauth yang mengatasnamakan AP miliknya, kartu jaringan WAJIB MEMATUHI PROTOKOL DAN LANGSUNG MEMUTUSKAN KONEKSI SEKETIKA!

EKSEKUSI SERANGAN VIA AIREPLAY-NG

- **Langkah 1: Monitor Mode:** Penyerang menyalakan kartu Wi-Fi ke Monitor Mode dan memindai BSSID AP target serta MAC address klien (STA).
- **Langkah 2: MAC Spoofing:** Penyerang memalsukan alamat MAC pengirim seolah-olah frame dibuat resmi oleh Access Point kampus.
- **Perintah Injeksi Paket:** sudo aireplay-ng --deauth 15 -a [MAC_AP] -c [MAC_KORBAN] wlan0mon
- **Dampak Instan:** Dalam 1 detik, laptop korban terputus total dari internet meskipun korban tidak melakukan kesalahan apapun!

TUJUAN GANDA PENYERANG: Deauth Flooding dipakai untuk 2 hal: 1) Melumpuhkan koneksi (DoS murni), atau 2) Memaksa korban melakukan reconnect otomatis agar penyerang dapat menyadap rekaman 4-Way Handshake di udara!

Bedah Istilah: Rogue Access Point (Ancaman dari Dalam)

Pemasangan perangkat nirkabel ilegal pada jaringan kabel internal kampus/perusahaan.

SKENARIO KEMUNCULAN ROGUE AP

- **Definisi Rogue AP:** Perangkat Access Point fisik tidak sah yang terhubung secara langsung ke jaringan kabel LAN gedung tanpa izin administrator IT.
- **Skenario Nyata di Kampus:** Seorang staf atau dosen merasa sinyal Wi-Fi di ruangannya kurang kuat, lalu membawa router Wi-Fi mini dari rumah dan mencolokkannya ke port stopkontak LAN kampus di bawah mejanya.
- **Niat Tidak Jahat, Tapi Berbahaya:** Meskipun tujuannya hanya ingin internet lancar di meja kerja, tindakan ini membuka lubang keamanan raksasa bagi seluruh kampus!

MENGAPA ROGUE AP SANGAT MEMATIKAN?

- **Mem-Bypass Seluruh Firewall Kampus:** Kabel LAN dinding umumnya terhubung langsung ke segmen Core Network atau Server Intranet kampus yang memiliki hak akses tinggi.
- **Konfigurasi Rentan / Default:** Router rumahan staf biasanya tidak dipasangi password kuat, menggunakan enkripsi default yang mudah dibobol, atau bahkan dibiarkan OPEN tanpa password!
- **Pintu Belakang (Backdoor) Hacker:** Penyerang dari luar gedung di area parkir dapat terhubung ke sinyal Wi-Fi router liar tersebut, dan seketika langsung berada di dalam jaringan kabel intranet kampus!

SOLUSI NETWORK ADMINISTRATOR: Wajib menerapkan fitur 'Port Security' (802.1X Port-Based Authentication dan Sticky MAC Address) pada semua switch edge LAN, sehingga port switch langsung mati otomatis jika dicolok perangkat asing.

Bedah Istilah: Evil Twin Attack & Kloning Sinyal

Membuat kembaran identik access point resmi untuk menjebak pengguna ke jaringan penyerang.

PRINSIP KERJA EVIL TWIN AP

- **Definisi Evil Twin:** Sebuah Access Point palsu milik penyerang yang dikonfigurasi dengan nama SSID dan MAC Address (BSSID) yang persis sama dengan AP resmi kampus.
- **Pemanfaatan Master Mode:** Penyerang menyalakan kartu nirkabel kedua ke mode Master menggunakan software seperti hostapd-mana atau wifiphisher.
- **Penguatan Sinyal Radio (Tx Power):** Penyerang menaikkan daya pemancar atau mendekati lokasi korban sehingga sinyal AP palsu terdeteksi jauh lebih kuat daripada AP resmi.

PERILAKU ALAMI SMARTPHONE KORBAN

- **Logika Roaming Otomatis:** Sistem operasi modern (Android, iOS, Windows) secara alami dirancang untuk selalu memilih sinyal pemancar terkuat ketika mendeteksi nama SSID yang sama demi menghemat baterai.
- **Tahap Eksekusi Kombinasi:** 1) Penyerang menembakkan Deauth Flood ke AP resmi kampus; 2) Korban terlempar keluar; 3) Saat reconnect otomatis, smartphone korban langsung menyambung ke Evil Twin karena sinyalnya paling dominan!
- **Korban Terperangkap:** Kini seluruh lalu lintas internet korban mengalir melalui laptop penyerang (Man-in-the-Middle penuh).

ANALOGI SEDERHANA: Evil Twin seperti mendirikan plang ATM Bank Mandiri palsu tepat di samping ATM resmi, lengkap dengan logo dan cat yang identik, agar nasabah memasukkan kartu ke mesin penipu.

SKENARIO PENCURIAN KREDENSIAL NYATA

Alur Evil Twin: Phishing Captive Portal SIAKAD

Bagaimana penyerang mengelabui mahasiswa untuk menyerahkan username dan password secara sukarela.

REKAYASA SOSIAL BERBASIS CAPTIVE PORTAL

- **1. Pengalihan DNS (DNS Spoofing):** Saat korban terhubung ke Evil Twin dan membuka situs web apapun, server DNS palsu penyerang mengarahkan semua lalu lintas ke server web lokal penyerang.
- **2. Halaman Login Web Tiruan:** Penyerang menampilkan halaman Captive Portal yang meniru persis tampilan form login SIAKAD Politani atau Wi-Fi Kampus.
- **3. Pesan Rekayasa Sosial:** Menampilkan pesan meyakinkan: 'Pembaruan Keamanan Jaringan Kampus: Silakan masukkan kembali NIM dan Password Akun SIAKAD Anda untuk melanjutkan akses internet.'

PANEN KREDENSIAL & AKIBAT FATAL

- **Mahasiswa Panik / Tidak Curiga:** Karena tadi baru saja koneksinya terputus (akibat deauth), mahasiswa mengira router kampus memang sedang mereset koneksi.
- **Kredensial Masuk ke Database Penyerang:** Begitu korban menekan tombol 'Login', username dan password langsung tersimpan dalam format teks terbuka di terminal penyerang.
- **Akses Internet Dialirkan:** Penyerang kemudian membuka akses internet korban melalui kartu modem 4G agar korban tidak sadar telah menjadi korban phishing!

EDUKASI PENTING MAHASISWA: Jika jaringan Wi-Fi WPA2 yang biasanya meminta password di menu pengaturan tiba-tiba meminta login ulang melalui halaman web browser mencurigakan, WASPADA! Jaringan tersebut kemungkinan besar adalah Evil Twin!

Serangan KRACK (Key Reinstallation Attack - 2017)

Ditemukan oleh Mathy Vanhoef: Membuktikan bahwa implementasi protokol yang cacat dapat meruntuhkan AES.

PENJELASAN GAMBLANG: BUKAN AES YANG DIBOBOL!

- **Miskonsepsi Populer:** Banyak berita media menulis: 'Enkripsi AES WPA2 Berhasil Dipecahkan Hacker' -> INI SALAH BESAR!
- **Fakta Ilmiah:** Algoritma enkripsi AES-128 tetap 100% utuh dan kokoh. Yang dieksploitasi oleh Mathy Vanhoef adalah LOGIKA STATE-MACHINE PADA PESAN 3 DARI 4-WAY HANDSHAKE.
- **Celah Penanganan Frame Hilang:** Protokol IEEE 802.11 dirancang untuk jaringan radio yang rawan paket hilang (lossy channel), sehingga memiliki mekanisme pengiriman ulang (retransmission) otomatis.

KONSEKUENSI PENGULANGAN PESAN 3

- **Aturan Standar 802.11 yang Cacat:** Ketika stasiun klien menerima Pesan 3 yang berulang, standar memerintahkan kartu jaringan untuk menginstal ulang kunci sesi PTK yang sama ke memori hardware.
- **Penyerang Sebagai MitM di Udara:** Penyerang sengaja menahan frame balasan ACK (Pesan 4) dari klien agar tidak sampai ke AP.
- **AP Mengirim Ulang Pesan 3:** Karena tidak menerima Pesan 4, AP berasumsi pesan hilang, lalu mengirim ulang Pesan 3 ke klien secara berulang-ulang.

TITIK BALIK SEJARAH KEAMANAN WI-FI: KRACK membuktikan bahwa keamanan tidak hanya ditentukan oleh kehebatan rumus matematika cipher, melainkan oleh ketelitian desain alur pertukaran pesan (state machine) protokol.

Mekanisme KRACK: Nonce Reset & Keystream Reuse

Bagaimana penginstalan ulang kunci mereset counter paket dan memicu pengulangan keystream pada AES-CCMP.

PETAKA RESET NONCE COUNTER KE NOL (0)

- **Fungsi Packet Counter (Nonce):** Pada mode AES-CCMP, setiap paket data yang dikirim memiliki nomor urut urut (Packet Number / Nonce) yang harus selalu bertambah untuk mencegah replay attack.
- **Bug Fatal Driver Wi-Fi Klien:** Saat klien menerima perintah 'Install Key' dari Pesan 3 yang berulang, driver kartu Wi-Fi mereset nomor urut Packet Counter KEMBALI KE NOL (0)!
- **Bencana Replay Keystream:** Kunci PTK yang sama persis kini dipasangkan dengan nilai Nonce yang kembali ke nol! Akibatnya, modul AES menghasilkan Keystream yang KEMBAR IDENTIK dengan paket-paket awal tadi!

DEKRIPSI DATA & PENANGGULANGAN

- **Dekripsi Paket Tanpa Tahu Password:** Karena keystream berulang, penyerang dapat melakukan analisis XOR antar dua ciphertext (C1 ⊕ C2 = P1 ⊕ P2) untuk mendekripsi paket data browsing korban!
- **Khusus Sistem Linux / Android 6.0+:** Implementasi wpa_supplicant bahkan memiliki bug lebih parah: kunci di-clearkan dari RAM sehingga paket dienkripsi dengan KUNCI NOL SEMUA (All-Zero Encryption Key)!
- **Solusi Penambalan (Patching):** Ditambal melalui patch firmware sistem operasi: Klien dilarang mereset Packet Number jika kunci yang diinstal adalah kunci yang sama.

STATUS KERENTANAN SAAT INI: Seluruh sistem operasi modern (Windows Update, patch kernel Linux, update Android/iOS akhir 2017) telah menambal bug KRACK. Router AP tidak perlu diganti, cukup perangkat klien yang di-update.

Serangan PMKID (2018): Meretas Tanpa Menunggu Korban

Ditemukan oleh Jens Steube (Author Hashcat): Mengeksploitasi fitur Fast Roaming 802.11r.

BATASAN SERANGAN 4-WAY HANDSHAKE KLASIK

- **Ketergantungan Pada Klien Aktif:** Pada metode klasik, penyerang harus berada di lokasi saat ada mahasiswa yang login, atau harus melakukan Deauth Flood ke klien yang sedang online.
- **Masalah Bagi Penyerang:** Jika di malam hari kampus sepi dan tidak ada satu pun orang yang terhubung ke Wi-Fi, penyerang tidak bisa menangkap handshake.
- **Hadirnya Solusi Serangan PMKID:** Jens Steube menemukan celah pada AP modern yang mengaktifkan fitur Fast BSS Transition (IEEE 802.11r / Roaming Cepat).

MEKANISME PENANGKAPAN HASH PMKID

- **Apa itu PMKID?:** PMKID (Pairwise Master Key Identifier) adalah nilai hash pengenal yang dihitung dari: PMKID = HMAC-SHA1-128(PMK, 'PMK Name' || MAC_AP || MAC_STA).
- **Hanya Butuh 1 Paket Asosiasi:** Penyerang cukup mengirimkan 1 frame Association Request dari laptopnya ke AP target menggunakan tool hcxdumptool.
- **AP Membocorkan Hash di Pesan 1:** AP langsung membalas dengan Pesan 1 yang menyertakan informasi elemen PMKID di dalamnya, TANPA BUTUH KLIEN LAIN ONLINE!
- **Offline Cracking Instan:** Hash PMKID langsung diumpankan ke Hashcat untuk di-crack secara lokal di komputer penyerang.

CARA MITIGASI PADA ROUTER: Jika fitur Fast Roaming (802.11r) tidak benar-benar dibutuhkan di lingkungan kampus, matikan opsi 802.11r pada pengaturan router MikroTik/Access Point untuk menutup celah PMKID.

Mengapa WPA-Personal (PSK) Tidak Layak di Enterprise?

Kelemahan arsitektur kata sandi bersama pada institusi kampus dan korporasi.

MASALAH KATA SANDI TUNGGAL BERSAMA

- **Single Shared Secret:** Seluruh ribuan mahasiswa, ratusan dosen, dan staf administrasi berbagi satu kata sandi Wi-Fi yang persis sama.
- **Kebocoran Yang Tak Terelakkan:** Cukup satu mahasiswa membagikan password ke teman luar kampus atau menuliskannya di papan pengumuman kantin, maka integritas seluruh jaringan langsung gugur!
- **Beban Operasional Mustahil:** Jika password bocor dan admin ingin menggantinya, admin harus mengubah konfigurasi di ratusan access point dan menyosialisasikan password baru ke ribuan pengguna!

KONSEKUENSI PENGELOLAAN PENGGUNA

- **Mahasiswa Lulus / Staf Resign:** Saat mahasiswa lulus atau pegawai berhenti kerja, mereka masih tetap memegang password Wi-Fi kampus dan bisa mengakses jaringan dari area parkir luar gedung.
- **Ketiadaan Jejak Akuntabilitas (No Audit Trail):** Jika terjadi insiden peretasan atau akses pornografi di jaringan nirkabel, admin tidak bisa melacak siapa pelakunya karena semua orang login dengan kredensial yang sama.
- **Solusi Industri:** Beralih mutlak ke standar otentikasi berbasis pengguna individu: WPA-Enterprise (IEEE 802.1X)!

RULE OF THUMB ADMINISTRATOR: WPA-PSK hanya diperuntukkan untuk jaringan rumahan (SOHO < 10 pengguna). Untuk skala sekolah, kampus, dan enterprise (> 50 pengguna), IEEE 802.1X adalah kewajiban mutlak!

Arsitektur IEEE 802.1X: Tiga Entitas Utama

Pemisahan peran gerbang nirkabel dan validasi akun pengguna pada backend server sentral.

1. SUPPLICANT (KLIEN)

- **Siapa Supplicant?:** Software agen otentikasi yang berjalan di perangkat akhir pengguna (laptop, smartphone, tablet).
- **Fungsi Utama:** Menyimpan kredensial identitas pengguna (Username/Password SIAKAD atau Sertifikat Digital) dan menegosiasikan otentikasi dengan AP.
- **Bawaan Sistem Operasi:** Telah tertanam otomatis pada Windows, Android, macOS, iOS, dan Linux (wpa_supplicant).

2. AUTHENTICATOR (AP / SWITCH)

- **Siapa Authenticator?:** Perangkat jaringan perantara (Access Point MikroTik, Ruijie, Cisco, atau Switch Managed).
- **Fungsi Penjaga Gerbang:** Bertindak sebagai 'Gatekeeper'. Port jaringan klien diblokir ketat dan hanya diizinkan melewatkan paket otentikasi EAP.
- **Tidak Tahu Password!:** AP tidak memverifikasi password; AP hanya membungkus paket EAP ke dalam protokol RADIUS menuju server backend.

3. AUTH SERVER (RADIUS)

- **Siapa Auth Server?:** Server otentikasi terpusat, umumnya menggunakan FreeRADIUS atau Microsoft NPS (Network Policy Server).
- **Koneksi ke Database Kampus:** Terhubung ke database akun induk institusi (Active Directory / OpenLDAP / SIAKAD Politani).
- **Penentu Keputusan:** Memvalidasi akun pengguna, lalu mengirim pesan RADIUS Access-Accept atau Access-Reject ke AP.

KEUNGGULAN MANAJEMEN TERPUSAT: Jika seorang mahasiswa lulus atau pegawai berhenti, admin cukup me-nonaktifkan akunnya di database server pusat. Pengguna tersebut otomatis terblokir dari seluruh access point kampus tanpa perlu menyentuh router!

Bedah Istilah: Controlled vs Uncontrolled Port pada 802.1X

Bagaimana Access Point menyaring lalu lintas sebelum dan sesudah proses otentikasi sukses.

STATUS PORT SEBELUM LOGIN (UNAUTHORIZED)

- **Controlled Port Terkunci Total:** Port virtual data ditutup rapat. Klien sama sekali tidak bisa mengirimkan paket browsing internet, ping, DNS query, atau lalu lintas data Layer 3.
- **Hanya Uncontrolled Port Yang Terbuka:** Access Point hanya mengizinkan satu jenis lalu lintas khusus: frame EAPoL (Extensible Authentication Protocol over LAN).
- **Tujuan Isolasi Awal:** Mencegah perangkat asing yang belum terdaftar melakukan scanning port, eksploitasi malware, atau penyadapan di jaringan lokal.

STATUS PORT SETELAH SUKSES (AUTHORIZED)

- **Pemberitahuan RADIUS Access-Accept:** Server RADIUS mengonfirmasi bahwa akun valid dan mengirimkan kunci enkripsi sesi master ke Authenticator.
- **Controlled Port Dibuka Penuh:** Access Point membuka blokir Controlled Port, mengalokasikan VLAN yang sesuai dengan profil pengguna, dan mengizinkan aliran data reguler.
- **Kunci Dinamis per Pengguna:** Setiap mahasiswa mendapatkan kunci enkripsi sesi temporal unik yang berbeda dengan mahasiswa di sebelahnya; tidak ada lagi penyadapan lateral!

ANALOGI GERBANG KAMPUS: Uncontrolled Port ibarat pos satpam (hanya untuk menunjukkan kartu tanda mahasiswa). Controlled Port ibarat pintu gerbang utama yang baru dibuka lebar setelah kartu diverifikasi sah.

Komparasi Metode EAP: PEAP-MSCHAPv2 vs EAP-TLS

Memilih metode Extensible Authentication Protocol yang tepat untuk skenario kampus dan industri.

PEAP-MSCHAPV2 (STANDAR KAMPUS & PENDIDIKAN)

- **Mekanisme Kerja:** Hanya Server RADIUS yang memasang sertifikat digital SSL/TLS. Klien memvalidasi sertifikat server, lalu membangun terowongan terenkripsi (TLS Tunnel).
- **Autentikasi di Dalam Terowongan:** Mahasiswa memasukkan Username dan Password akun SIAKAD di dalam terowongan yang telah terenkripsi aman.
- **Kelebihan Implementasi:** Sangat mudah diterapkan pada ribuan smartphone/laptop mahasiswa tanpa perlu menginstal file sertifikat pada perangkat masing-masing.
- **Celah yang Harus Diwaspadai:** Jika mahasiswa menonaktifkan opsi 'Validate Server Certificate' di HP-nya, jaringan rentan disusupi Evil Twin AP!

EAP-TLS (STANDAR KEAMANAN TERTINGGI / MILITER)

- **Autentikasi Sertifikat Digital Ganda:** Menggunakan Sertifikat Digital X.509 pada Server RADIUS DAN pada perangkat klien (Mutual Certificate Authentication).
- **Tanpa Password Sama Sekali!:** Pengguna tidak perlu mengetik password; autentikasi divalidasi melalui kepemilikan pasangan kunci privat dan sertifikat pada perangkat.
- **Kebal 100% Phishing & Pencurian Akun:** Mustahil dipancing oleh Evil Twin atau Captive Portal palsu karena penyerang tidak memegang kunci privat sertifikat klien.
- **Peruntukan Khusus:** Sangat ideal untuk laptop dinas pimpinan kampus, server akademik, perangkat keuangan, dan mesin industri kritikal.

REKOMENDASI BEST PRACTICE: Gunakan PEAP-MSCHAPv2 untuk Wi-Fi mahasiswa umum (skalabilitas tinggi), dan gunakan EAP-TLS untuk Wi-Fi staf rektorat & server administrasi (keamanan mutlak).

Protected Management Frames (IEEE 802.11w / PMF)

Solusi standar industri untuk mematikan serangan Deauthentication Flooding secara permanen.

BAGAIMANA CARA KERJA PMF?

- **Mengenkripsi Frame Manajemen:** Standar IEEE 802.11w (PMF) memperluas enkripsi kriptografis hingga ke frame manajemen (Deauthentication, Disassociation, dan Action Frames).
- **Protokol BIP (Broadcast Integrity Protocol):** Menggunakan algoritma kriptografi AES-128-CMAC untuk menandatangani frame manajemen siaran secara digital.
- **Tanda Tangan Keaslian Pengirim:** Setiap frame Deauth yang dikirim oleh AP resmi dibubuhi tanda tangan digital kriptografis yang hanya bisa dibuat oleh pemegang kunci sesi yang sah.

DAMPAKNYA TERHADAP HACKER DEAUTH

- **Serangan aireplay-ng Gagal Total!:** Ketika penyerang menembakkan frame deauth palsu, smartphone atau laptop klien yang mengaktifkan PMF memeriksa tanda tangan digital frame tersebut.
- **Penolakan Frame Palsu:** Karena hacker tidak memegang kunci kriptografis sah, frame palsu ditandai sebagai sampah dan LANGSUNG DIBUANG OLEH KARTU JARINGAN!
- **Koneksi Tetap Stabil:** Meskipun hacker menembakkan ribuan frame deauth per detik, koneksi mahasiswa tidak pernah terputus sedikitpun!
- **Status Regulasi:** PMF bersifat OPSIONAL pada WPA2 dan DIWAJIBKAN MUTLAK pada standar WPA3.

SETTING DI ROUTEROS MIKROTIK: Pada menu Security Profile MikroTik: Atur parameter 'Management Protection' dari 'disabled' menjadi 'allowed' (untuk kompatibilitas) atau 'required' (untuk keamanan maksimal).

Bedah Istilah: WIDS & WIPS pada Jaringan Kampus

Sensor radio otomatis untuk mendeteksi ancaman dan menetralisir access point liar.

WIDS (WIRELESS INTRUSION DETECTION SYSTEM)

- **Deteksi Ancaman 24/7:** Memanfaatkan sensor radio khusus yang terus memindai kanal spektrum nirkabel di seluruh gedung secara non-stop.
- **Pendeteksian Rogue AP:** Mendeteksi secara otomatis kemunculan AP tidak sah yang MAC-nya tidak terdaftar dalam database resmi kampus.
- **Pendeteksian Evil Twin & Phishing:** Membunyikan alarm peringatan seketika saat ada pemancar yang memancarkan SSID resmi kampus namun memiliki BSSID berbeda atau sinyal abnormal.
- **Deteksi Serangan DoS & Jamming:** Merekam lonjakan drastis volume frame deauth di udara atau anomali noise frekuensi radio.

WIPS (WIRELESS INTRUSION PREVENTION SYSTEM)

- **Mitigasi Aktif Otomatis:** Bukan sekadar membunyikan alarm; WIPS langsung mengambil tindakan pemblokiran tanpa menunggu instruksi manusia.
- **Teknik Rogue Containment:** Jika sensor mendeteksi mahasiswa mencoba terhubung ke Evil Twin milik hacker, sensor WIPS akan menembakkan frame deauth terarah khusus ke laptop mahasiswa tersebut untuk MEMUTUSKANNYA DARI AP PALSU!
- **Pemisahan Port Switch Fisik:** WIPS mengirimkan perintah via SNMP ke switch edge untuk langsung mematikan port LAN fisik yang menjadi sumber colokan Rogue AP.
- **Hasil Lapangan:** Serangan dinetralisir dalam hitungan detik sebelum sempat memakan korban.

PERINGATAN REGULASI & KESELAMATAN: Teknik Rogue Containment (penembakan deauth otomatis) harus dikonfigurasi dengan sangat hati-hati agar tidak salah menembak AP milik tetangga gedung resmi yang dapat memicu tuntutan hukum.

Blueprint Segmentasi & Hardening WLAN Kampus Politani

Rancangan multi-SSID, isolasi VLAN, dan kebijakan keamanan untuk lingkungan institusi.

Nama SSID	VLAN ID	Metode Otentikasi	Fitur Hardening Wajib	Hak Akses Jaringan
POLITANI-STAFF	VLAN 10	WPA2/WPA3 Enterprise (PEAP)	PMF Required, Bandwidth Uncapped	Akses Penuh: Intranet, SIAKAD Dosen, Server Akademik
POLITANI-MHS	VLAN 20	WPA2 Enterprise (RADIUS)	Bandwidth Quota, Peer-to-Peer Drop	Akses Terbatas: Internet Kampus & Portal Mahasiswa
POLITANI-GUEST	VLAN 30	Captive Portal Web Login	Client Isolation ON, PMF Allowed	Akses Publik: Hanya Port 80/443 ke Gateway Internet
POLITANI-IOT	VLAN 40	WPA2-PSK (Password Acak 32 Char)	MAC Whitelist, No Broadcast	Hanya Komunikasi ke Server MQTT / Sensor Kebun

Catatan Penting Lapangan: Aturan Emas: Aktifkan fitur Client Isolation (default-forwarding=no) pada VLAN Mahasiswa dan Tamu agar laptop pengguna tidak bisa saling serang secara lateral!

Bedah Istilah: Client Isolation & Default Forwarding

Memutus rantai serangan lateral (lateral movement) di antara pengguna pada satu access point yang sama.

BAHAYA JARINGAN WIRELESS TANPA ISOLASI

- **Kondisi Default Access Point:** Secara default, Access Point bertindak seperti switch nirkabel: seluruh perangkat yang terhubung berada dalam satu broadcast domain Layer 2 yang sama.
- **Surga Bagi Hacker di Kafe/Kampus:** Seorang hacker di kantin kampus dapat menjalankan software pemindai (Nmap) untuk mencari port rentan pada laptop mahasiswa lain yang sedang duduk di sebelahnya.
- **Serangan ARP Poisoning Lokal:** Penyerang membanjiri tabel ARP sehingga seluruh lalu lintas browsing teman di sebelahnya berbelok melewati laptop penyerang.
- **Penyebaran Malware Otomatis:** Worm dan ransomware dapat menular cepat antar laptop melalui celah protokol file sharing Windows (SMB port 445).

FUNGSI CLIENT ISOLATION PADA MIKROTIK

- **Perintah 'default-forwarding=no':** Pada konfigurasi MikroTik RouterOS di menu Wireless Interface: Matikan opsi default-forwarding.
- **Mekanisme Pemblokiran:** Access Point secara tegas MEMBLOKIR SEMUA KOMUNIKASI LANGSUNG ANTAR-KLIEN NIRKABEL yang terhubung ke radio tersebut.
- **Hanya Boleh Bicara ke Gateway:** Setiap laptop pengguna hanya diizinkan berkomunikasi ke arah router gateway untuk keluar menuju internet.
- **Hasil Proteksi:** Penyerang tidak bisa melakukan ping, tidak bisa memindai port, dan tidak bisa melancarkan ARP poisoning ke pengguna lain!

PANDUAN KONFIGURASI LAPANGAN: Setting wajib untuk semua hotspot publik: 1) Matikan default-forwarding pada interface wireless; 2) Pasang rule firewall drop forward antar-IP di subnet tamu.

Rangkuman Pertemuan 2 & Jembatan ke Pertemuan 3

Menuntaskan modul keamanan logis dan bersiap melangkah ke modul perangkat keras gelombang radio.

SINTESIS MODUL KEAMANAN (PERTEMUAN 1 & 2)

- **Pertahanan Holistik:** Keamanan sistem nirkabel mencakup kriptografi data (AES-CCMP), autentikasi identitas individu (IEEE 802.1X / RADIUS), dan perlindungan integritas frame kontrol (PMF 802.11w).
- **Mitigasi Ancaman Aktif:** Deauth flood dinetralisir oleh PMF; Rogue AP ditangkal oleh Port Security & WIPS; Evil Twin dicegah oleh validasi sertifikat EAP-TLS/PEAP; serangan lateral dihentikan oleh Client Isolation.
- **Fondasi Engineer Lengkap:** Mahasiswa TRK kini menguasai arsitektur keamanan logis nirkabel dari level frame hingga skala enterprise.

PENGANTAR MENUJU PERTEMUAN 3: ANTENA WIRELESS!

- **Pertanyaan Besar Berikutnya:** 'Sehebat apapun enkripsi dan arsitektur keamanan kita, bagaimana sinyal Wi-Fi tersebut merambat di alam nyata?'
- **Peran Gerbang Fisik (Antena):** Antena adalah pintu gerbang fisik yang menentukan ke mana energi sinyal diarahkan, seberapa jauh jangkauannya, dan seberapa bersih dari interferensi.
- **Materi Pertemuan 3 (Minggu XI):** Kita akan masuk ke dunia fisik: Panduan Praktis Antena untuk Network Engineer (memahami satuan dBm/dBi/EIRP, beamwidth HPBW, polarisasi V/H, downtilt, dan link budget lapangan)!

ARAHAN PRAKTIKUM MINGGU INI: Buka modul Praktikum.md: Kita akan mempraktikkan simulasi Deauthentication Attack di lingkungan lab tertutup, konfigurasi FreeRADIUS untuk otentikasi akun, dan setting hardening MikroTik default-forwarding=no.